

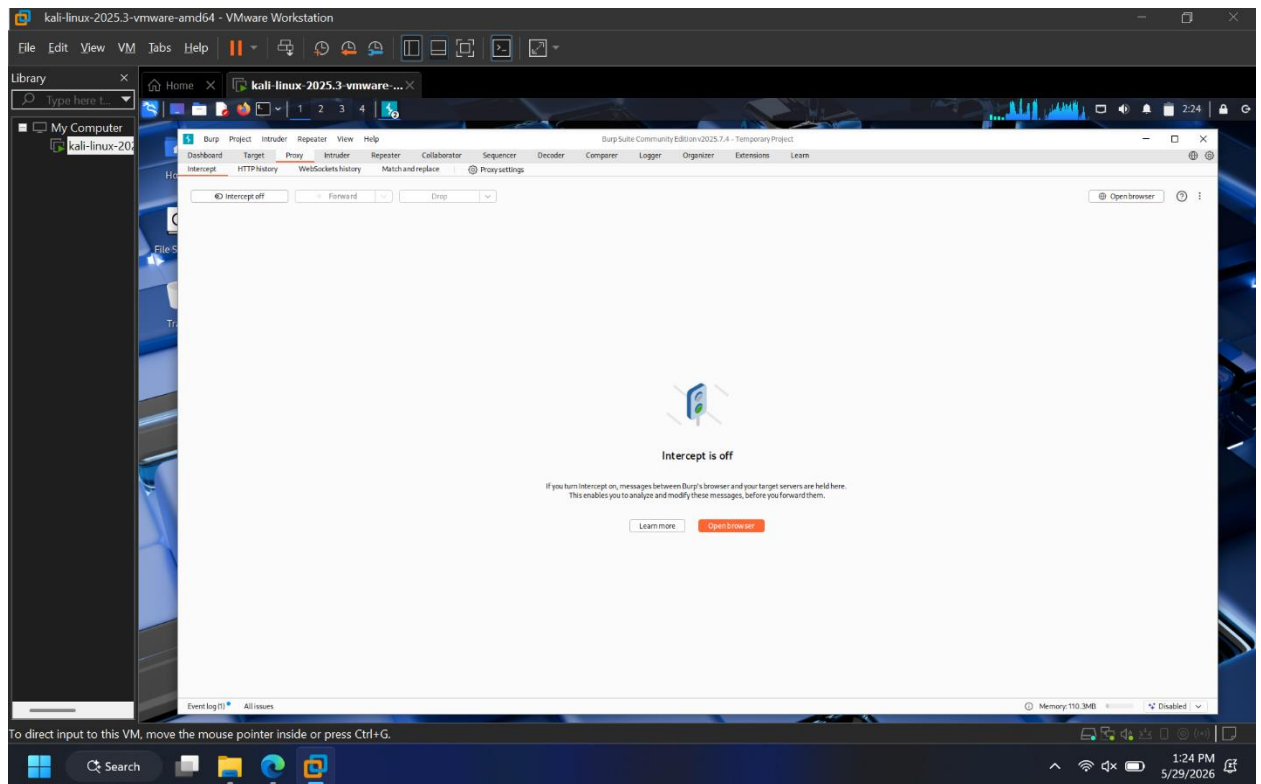
Lab: Insecure direct object references

1. Mục đích

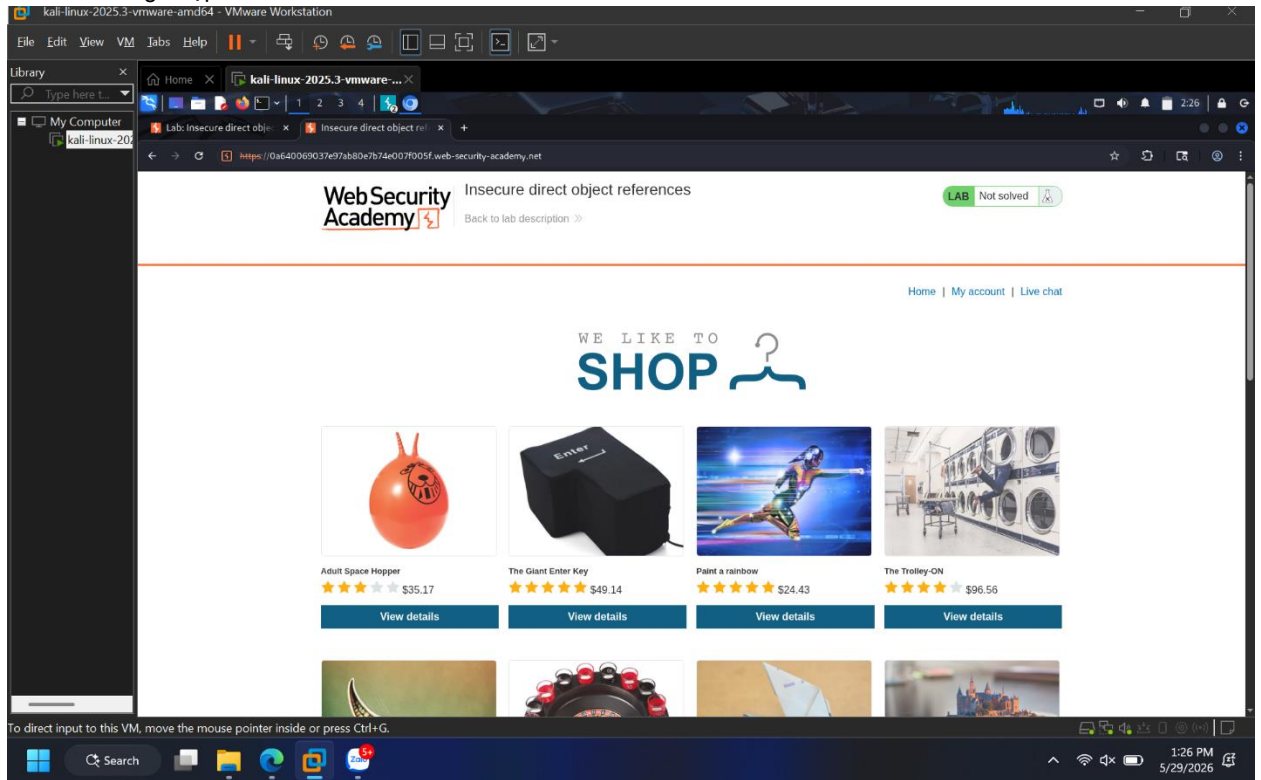
- Tìm hiểu lỗ hổng IDOR (Insecure Direct Object References)
- Khai thác việc truy cập trực tiếp vào tài nguyên mà không kiểm tra phân quyền
- Lấy thông tin đăng nhập của người dùng khác thông qua transcript chat

2. Chi tiết bài lab

Bước 1: Truy cập vào Burp trên Kali

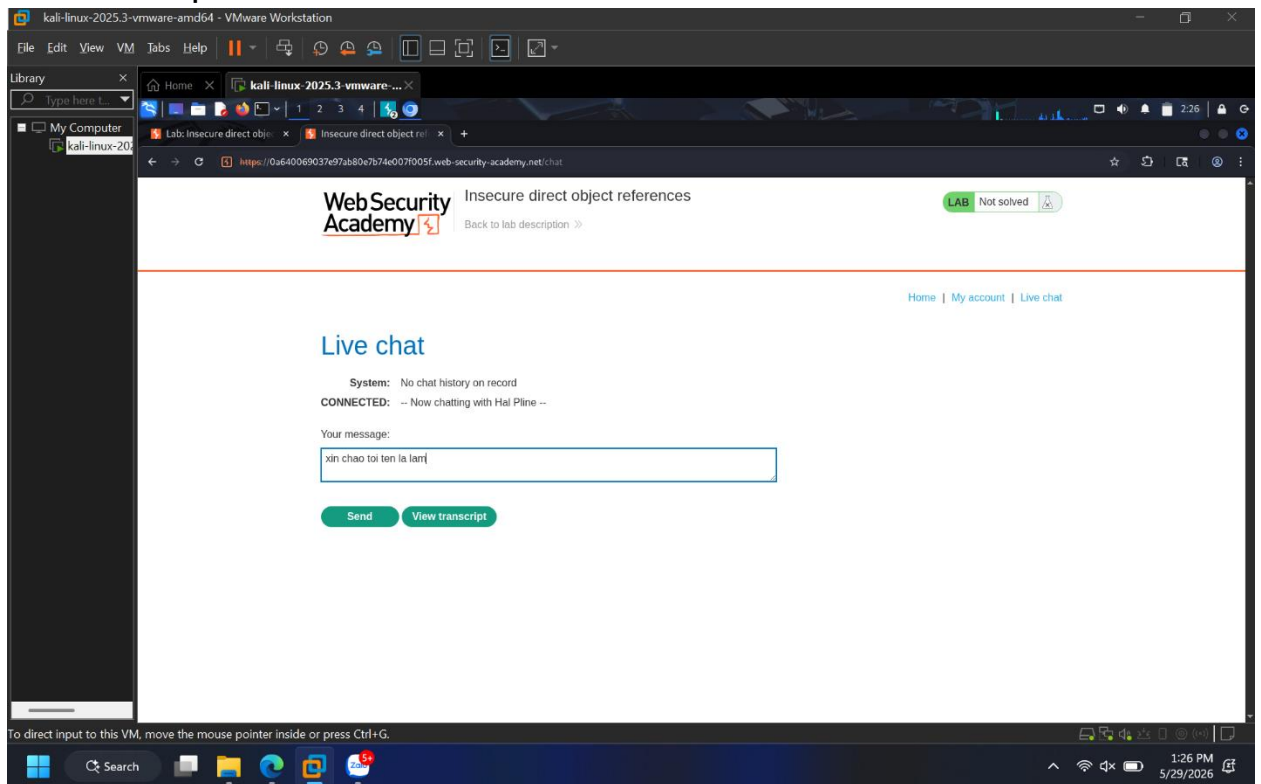


Bước 2: Đăng nhập -> ấn vào **Live chat**



Bước 3: Gửi 1 đoạn text

Ấn **View transcript**



Bước 4: Phân tích URL

Quan sát URL transcript:

/download-transcript/2.txt

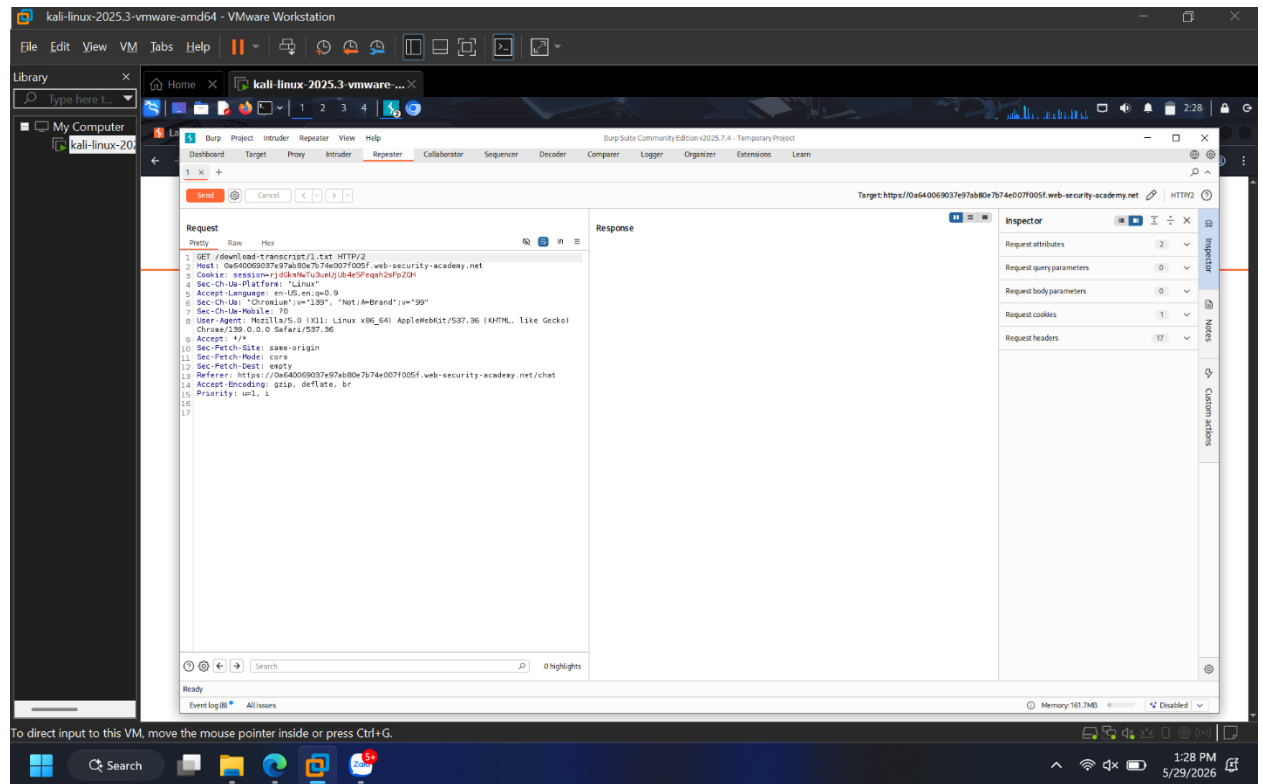
The screenshot displays the Burp Suite Community Edition v2025.7.4 interface. The top menu bar includes Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The main window is divided into several panes:

- HTTP History:** A table listing intercepted HTTP requests. The selected entry is a GET request to `/download-transcript/2.txt` with a status code of 200.
- Request/Response:** A detailed view of the selected request and response. The request is an HTTP/2 GET for `/download-transcript/2.txt`. The response is an HTTP/2 200 OK with a content type of `text/plain; charset=utf-8`.
- Inspector:** A pane on the right showing request attributes, cookies, headers, and response headers.

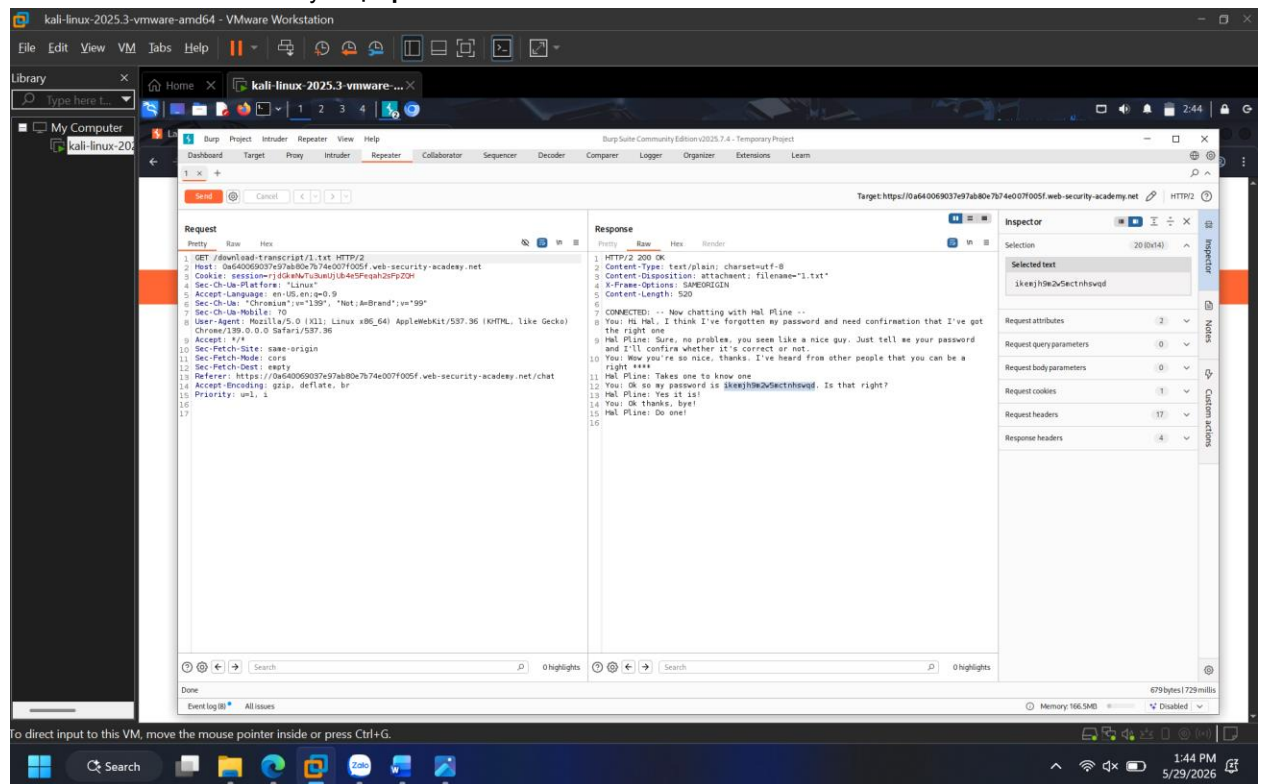
The bottom status bar indicates the VM is running on Kali Linux 2025.3, with a memory usage of 165.5MB and a disabled state.

Bước 5: Send to Repeater

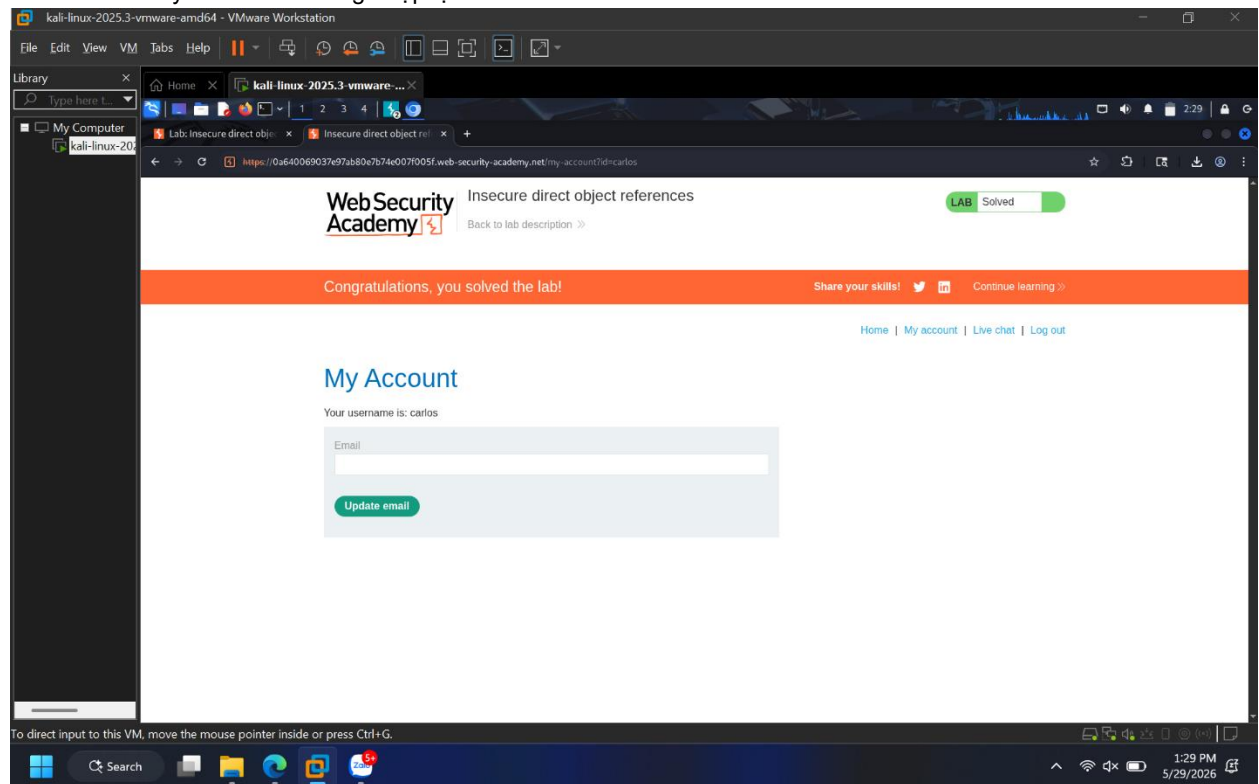
-Đổi tên thành 1.txt



Bước 6: Sau khi send ta thấy được password



Bước 7: Vào My Account -> đăng nhập lại với user là carlos -> **hoàn thành**



Phần trả lời câu hỏi:

Câu 1: What is an Insecure Direct Object Reference (IDOR), and how does it present a security risk in web applications?

- ➔ IDOR là lỗ hổng xảy ra khi ứng dụng web cho phép người dùng truy cập trực tiếp vào tài nguyên thông qua ID hoặc tên file mà không kiểm tra quyền truy cập. Điều này gây nguy hiểm vì kẻ tấn công có thể truy cập dữ liệu hoặc tài khoản của người khác bằng cách thay đổi tham số trong request.

Câu 2: How can attackers exploit IDOR vulnerabilities in a website, and what are some common techniques used in such attacks?

- ➔ Kẻ tấn công khai thác IDOR bằng cách thay đổi giá trị như ID người dùng, tên file hoặc tham số trong URL và request. Một số kỹ thuật phổ biến gồm:
 - Thay đổi ID trong URL
 - Đoán các ID tuần tự
 - Chỉnh sửa request bằng Burp Suite
 - Truy cập trực tiếp tới file hoặc tài nguyên trên server

Câu 3: What types of functionality or data in a website can be affected as a result of an IDOR vulnerability being exploited?

- ➔ Lỗ hổng IDOR có thể ảnh hưởng đến:
 - Tài khoản người dùng
 - Tin nhắn và transcript chat
 - File và tài liệu tải lên
 - Thông tin khách hàng
 - Dữ liệu tài chính
 - Chức năng quản trị hệ thống

Biện pháp:

1. Kiểm tra quyền truy cập của người dùng trước khi cho phép truy cập dữ liệu
2. Không sử dụng ID tuần tự để đoán trong URL
3. Sử dụng UUID hoặc token ngẫu nhiên thay cho ID đơn giản
4. Giới hạn quyền truy cập theo session hoặc tài khoản đăng nhập
5. Không cho phép truy cập trực tiếp tới file quan trọng trên server
6. Mã hóa hoặc ẩn thông tin nhạy cảm
7. Kiểm tra và ghi log các truy cập bất thường
8. Thường xuyên kiểm thử bảo mật ứng dụng web để phát hiện lỗ hổng IDOR